

VulnScan-Pro

An Integrated Web Application Security Testing Suite

1. Project Overview

VulnScan-Pro is an end-to-end web application security project built to demonstrate practical offensive and defensive security engineering skills. Instead of a single script or a single demo, it brings together four connected pieces: a deliberately vulnerable test application, an automated vulnerability scanner, a visual reporting dashboard, and a cryptography demonstration module. Together they simulate the full workflow a security engineer follows in the real world — from spinning up a target, to scanning it, to presenting findings in a way a non-technical stakeholder can understand.

The project is designed as a portfolio piece: it is hands-on, fully self-contained (runs locally via Docker), and covers both the attacker's perspective (exploiting vulnerabilities) and the defender's perspective (detecting and reporting them).

2. Why This Project Matters

- Shows applied knowledge of the OWASP Top 10 categories of vulnerabilities, not just theory.
- Combines four distinct skill sets — secure/insecure backend coding, automation/tooling, frontend data visualization, and applied cryptography — in one cohesive repository.
- Mirrors real-world security tooling (in the spirit of tools like DVWA and SQLMap) while being fully original, custom-built code.
- Produces tangible, demo-able outputs: live scan results, a CVSS-scored dashboard, and exportable PDF/HTML reports — ideal for interviews, college submissions, or GitHub visibility.

3. System Architecture

The project is split into four independent but interlinked modules, all orchestrated together using Docker Compose:

3.1 VulnApp — Deliberately Vulnerable Target

A Flask/Node.js web application that intentionally contains common web vulnerabilities, acting as a personal, custom-built equivalent of DVWA. This is the application the scanner is pointed at.

- SQL Injection — vulnerable query endpoints for classic and blind injection.
- XSS — both Stored and Reflected variants.
- IDOR (Insecure Direct Object Reference) — accessing other users' data via manipulated IDs.
- Broken Authentication — weak session/login handling.
- CSRF — state-changing actions without proper token protection.
- XXE (XML External Entity) — unsafe XML parsing.

3.2 Scanner — Python CLI Automated Detection Tool

The centerpiece of the project: a custom Python command-line tool that crawls VulnApp and automatically detects the vulnerabilities seeded into it.

- SQLMap-style injection detection logic.
- An XSS payload fuzzer that tries multiple encoded payloads against input fields.
- An HTTP header analyzer (checks for missing security headers, weak cookie flags, etc.).
- An automated report generator that outputs findings as HTML and PDF.

3.3 Dashboard — React Frontend

A visual layer on top of the scanner's findings, meant to make results easy to read at a glance — this is the part most likely to impress in a demo.

- A vulnerability heatmap across the scanned application.
- CVSS score display per finding, for severity context.
- Live scan progress while the scanner runs.
- One-click export of results to PDF.

3.4 Crypto Module — Hashing & Encryption Demo

A standalone educational module showing the practical difference between weak and strong cryptographic choices.

- MD5 vs bcrypt comparison — speed and crackability.
- Caesar cipher break demonstration.
- JWT tampering / forgery demo to show insecure token handling.
- A simple hash cracker and a weak-cipher detector.

4. Technology Stack

Layer	Technologies
Backend (VulnApp)	Python (Flask), SQLite, Docker
Scanner	Python, requests, BeautifulSoup, reportlab
Frontend (Dashboard)	React, Recharts, TailwindCSS
DevOps	Docker Compose, GitHub Actions

5. Repository Structure

```
VulnScan-Pro/  
■■■ vulnapp/      # Target Flask app (deliberately vulnerable)  
■■■ scanner/      # Python CLI scanning tool  
■■■ dashboard/    # React frontend  
■■■ crypto-demo/  # Crypto module (hashing / encryption demos)  
■■■ reports/      # Sample scan outputs  
■■■ docker-compose.yml  
■■■ README.md     # Detailed docs + screenshots
```

6. Skills Demonstrated

- Secure coding awareness — built by intentionally writing insecure code, which requires understanding exactly why it is insecure.
- Offensive security / penetration testing fundamentals (OWASP Top 10 categories).
- Tool building — writing automation that performs the work a manual pentester would do.
- Full-stack development — Flask backend, React frontend, working together via an API/data layer.
- Applied cryptography concepts — hashing strength, cipher weaknesses, token security.
- DevOps fundamentals — containerizing a multi-service project with Docker Compose, basic CI awareness with GitHub Actions.

7. Summary

VulnScan-Pro is built to be more than a single script — it is a small, working security ecosystem: a vulnerable target, an automated scanner that finds real issues in it, a dashboard that visualizes those findings, and a crypto module that reinforces the 'why' behind secure design choices. It is intended as a portfolio-ready project to showcase on GitHub and walk through in interviews or demos.